PIC Code-vs-Workflow Review

AlphaHelion Procurement Intelligence Cloud. Review of 29 Oct 2026 against `docs/PIC_Process_Flows.md`, the Blueprint and the Technical Document. Code at commit `1ff021b`.

Contents

1. Summary
2. How the review was done
3. Findings and fixes by area
4. Database constraints added (migration 0007)
5. MRP performance
6. Behaviour changes users will notice
7. Open items and decisions
8. Test evidence

1. Summary

Area	Findings	High severity	Status
F2 Guided buying → requisition · F9 Material governance	16	1	15 fixed; 1 left as is (exact ₹10 L band edge, §7)
F3 Sourcing → award · F4 Contract lifecycle	17	3	17 fixed
F5 Purchase order · F6 Receiving and quality	16	5	16 fixed (2 moved to the F3/F4 and F7/F8 owners)
F7 Invoice → payment · F8 Supplier onboarding	15 (+1 from F5/F6)	4	16 fixed
Platform: workflow engine, events, ERP queue, security	12	2	12 fixed (1 partly; schema in 0007)
Total	**≈ 89**	**15**	**All fixed except one deliberate edge case**

The core flows F1–F9 were implemented and ran end to end. The review found three kinds of defect that the happy-path tests did not reveal:

- **Money controls:**
  - a supplier could invoice another supplier's order;
  - a receipt could be invoiced twice before the first invoice posted;
  - blocked or sanctioned suppliers were still paid;
  - negative quantities were accepted.
- **Approval controls:**
  - change orders skipped PO approval;
  - supplier redlines skipped Legal;
  - a contract's submitter could approve it;
  - a bank change could pass with one approver instead of two.
- **Dead ends:** objects that could get stuck with no next step, such as multi-lot receipts, partly received orders, rejected PO approvals and requisitions that could not be cancelled.

All of these are fixed, each with a test. The full backend suite passes on one database: 389 tests.

2. How the review was done

- **Five read-only reviewers**, one per area, read every service, API route and screen of their area. For each, they checked:
  - every flow step and gateway;
  - the state machine;
  - roles and scopes;
  - segregation of duties;
  - the audit trail and the events;
  - that the screens send what the API expects.
- **Evidence rule:** every finding had to name file and line, the exact code, the flow step or spec section it breaks, and a concrete failing scenario. Unproven suspicions were dropped. The integrator then verified the high-severity findings in the code before any fix started.
- **Five fix engineers**, one per area, each with its own files and test database. Every fix is covered by tests in `backend/tests/pic/test_review_*.py`.
- **Integration:** migration 0007, the remaining alignments, and one full run of the backend suite on one database.

3. Findings and fixes by area

3.1 F2 Requisitions · F9 Material master

#	Finding	Fix
1 (high)	Negative quantity or price accepted; it netted down the requisition value, so approval and the budget could be dodged	`qty > 0`, `price ≥ 0` in the API and the service; database CHECKs
2	Contract buying (channel 1) could not be used from the API or the screen	Contract lines carry `contract_line_id` and the contract price
3	A STOCK purchase without a material skipped account assignment and the budget	STOCK needs a material
4	Quote policy applied only to free-text lines, and the quote count was self-declared	Applies to every unstructured line; each quote needs a supplier, reference and date
5	Only the first cost object of a multi-cost-object requisition was approved	One approver task per cost object, all must approve
6	DMN-01 ignored category and purchase-type rule versions; the simulator did not	Resolved with category and purchase type
7	Re-approval after a change used the edited line only	Uses the whole requisition; an account-type change also restarts approval
8	Anyone with `req:create` could edit any requisition	Requester only; after approval, requester or buyer
9	Material-request merge open to every user, in any state	Requester or steward, listed active candidates only
10	No requisition cancel: budget stayed committed forever	Cancel or withdraw releases the budget and closes tasks
12	Duplicate check ignored requests still in progress	In-progress requests are scored as candidates
13	Unmatched punch-out items became catalogue lines; prices unchecked	Become free text; price tolerance against the catalogue
14–16	Concurrent category-budget overrun, 500 on an empty requisition, missing audit events, override without reason	Fixed

3.2 F3 Sourcing · F4 Contracts

#	Finding	Fix
1 (high)	One malformed supplier bid broke the event close and stopped all scheduled steps of the company	Bids validated on submission; timers isolated (§3.5)
2 (high)	Suppliers saw the buyer's baseline price and savings target	Stripped for supplier users

#	Finding	Fix
3 (high)	A supplier redline could bypass Legal; the audit lacked the new text	Supplier redlines are non-standard until a contract manager reviews them; before and after text audited
4	The submitter could approve their own contract	Submitter excluded
5	Any buyer could publish, close or award a category manager's event	Owner or category manager only
6	Multi-line events were evaluated and awarded on one line only	One item per event (enforced in the service and the screen)
7	Capacity-constrained scenario ignored the maximum share	Applied for every supplier count
8	Index resets compounded after an extension	Base is always the negotiated price
9	Contract consumption ignored PO changes; cancellation subtracted the wrong quantity	Recomputed from the live PO lines on release, change, cancel and close
10	Suppliers saw internal approval comments	Stripped for supplier users
11	A non-standard TERMS amendment skipped Legal	Routed through Legal
12	Award and consumption alerts never notified anyone	Notifications added
13–17	Auction rank visible, scores lost after a new round, blocked suppliers could still bid, fixed company code, no cancel button	Fixed

3.3 F5 Purchase orders · F6 Receiving

#	Finding	Fix
1 (high)	A receipt with two quality-checked lines could never be fully decided	Receipt status from all its lots; ERP posting at the last decision
2 (high)	A receipt could be reversed while its invoice was approved; the invoice then posted without a receipt	Reversal blocked by any invoice in process
3 (high)	The service-entry value cap ignored sheets awaiting approval	Counts pending sheets; re-checked at approval
4 (high)	Negative or zero quantities accepted on receipts, ASNs and service entries	API, service and database checks
5 (high)	Change orders bypassed PO approval and the contract-price deviation control	Price deviation needs a reason and approval; a change into a higher value band is approved first
6	A partly received order was a dead end	Change, re-confirmation and short-close
7	A mixed receipt in quality hold could not be reversed	Each line reversed from its own stock

#	Finding	Fix
8	A new PO version had no confirmation deadline	A deadline per version
10	Cancelling a PO left an approvable service entry	Cancel refused while service entries are open
11	No way back after a rejected PO approval; no cancel after confirmation	Resubmit; cancel from approval and from confirmation
12	The ERP cancellation was skipped while the release was still retrying	Cancellation follows the release
14	Rejected goods could not be replaced	Replacement re-opens the quantity
15–16	Schedule edits after transmission, e-way bill at exactly ₹50,000, IST date in screens, change-order button for every role, ignored idempotency keys, 500 on unknown lines	Fixed

3.4 F7 Invoice-to-pay · F8 Supplier onboarding

#	Finding	Fix
1 (high)	"Re-run match" cleared a duplicate-invoice hold	Duplicate hold survives re-matching; Reject button added
2 (high)	A supplier could invoice another supplier's PO	PO must belong to the supplier and company
3 (high)	The same receipt could be invoiced twice before the first invoice posted	Unposted invoices count against the available quantity, under a lock
4 (high)	Blocked or sanctioned suppliers were still paid and could invoice	Payment blocked and capture refused; audited unblock
5	Credit notes and invoice lines were unvalidated, so payments could go negative	Validated; payment run skips non-positive amounts
6	Due date ignored the PO terms; "2/10 N45" was read as 21,045 days	PO terms; net days parsed correctly
7	A price difference could not be cleared by a credit note; AP re-priced the PO alone	Value credit notes; price acceptance needs a buyer
8	Price tolerance applied per unit, so the ₹500 cap was dead	Applied to the line value
9	Invoice marked PAID regardless of the ERP payment	PAID only when the ERP confirms; payments reconciled
10	A duplicate or sanctions screening result never gated qualification	Disposition required before qualification
11	No screen for bank details and certificates	Portal profile panel; bank-change dialog
12–13	Certificate expiry relied on supplier data; a bank-change approval verified every certificate	Rule-driven expiry; explicit verification
14–16	Qualification not state-guarded, invoice-number collisions, OTIF wrong with schedules	Fixed
(platform F1)	A bank change after onboarding needed only one finance approver	Always the bank-change process with two approvers

3.5 Platform

#	Finding	Fix
F1 (high)	Multi-role approval chains without a process instance collapsed to one approval	Chain kept on the task
F2 (high)	One failing timer stopped all scheduled steps for every company	Timers and companies isolated; retry, then parked
F3	Parallel approvals finishing together could leave the object stuck	Approval group locked
F4	MFA codes could be brute-forced	Account lockout (10 failures in 15 minutes), failures audited
F5	Monitoring metrics read zero on Neon (row-level security)	Read per company
F6	One bad ERP answer blocked the whole ERP queue	Each message isolated; dead letter after 8 attempts
F7	Tally had no lookup before a retry	Lookup added (tested against mocks only)
F8	Same-date rule versions resolved arbitrarily	Deterministic order; duplicates refused
F9	Escalation never reached a manager	Manager role added from level 2
F10	Supplier users could read internal standard prices	Restricted
F11	One company's request ran every company's background work	Scoped to the company
F12	Outbox retries had no back-off	Back-off with a stored next-attempt time (migration 0007)

4. Database constraints added (migration 0007)

The services now refuse these cases, and the database also refuses them, in case a code path skips the check:

- **Outbox:** a `next_attempt_at` column with an index, for the stored retry back-off.
- **Unique numbers:** the internal invoice number is unique per company, and the credit-note number is unique per supplier.
- **No negative or zero values:**
  - requisition and PO-line quantities and amounts;
  - ASN, receipt and service-entry lines;
  - inspection-lot decisions and return deliveries;
  - budget commitments.
- **Service entries:** the approved service value can't exceed the PO line value.

The data in every seeded company was checked against these constraints before they were added: no row breaks them.

5. MRP performance

Run	Before	After
1,000 materials (profiled)	314 s, 32,002 SQL statements	27 s, 72 statements
5,000 materials	3,306 s	52–179 s (machine under load)
50,000 materials	about 8–9 h (projected)	**681 s, measured** (target 600 s)

- **Same results:** identical to the old code in six run modes, compared field by field.
- **Migration 0006:** adds 17 indexes.
- **Still to do for the 10-minute target:**
  - measure on a quiet machine or a production-size database;
  - decide whether to drop the per-order link row;
  - return a summary instead of every planned order.

6. Behaviour changes users will notice

Who	Change
Requesters	Quotes need a supplier, reference and date. Requisitions can be withdrawn. Every cost centre approves its share.
Buyers	Change orders that raise the value into a higher band, or deviate from the contract price, wait for approval. Orders can be short-closed, resubmitted after rejection, or cancelled after confirmation. Sourcing events have one item each.
Contract managers	Supplier redlines must be accepted or restored before submitting. A second contract manager approves your contracts.
AP / Finance	Duplicate holds stay until decided. Invoices show "in payment" until the ERP confirms. Blocked suppliers are skipped in payment runs. Accepting a higher price needs a buyer.
Supplier managers	Screening results must be cleared before qualification. Certificates must be verified explicitly.
Suppliers	Bank details and certificates are entered in the portal. Award decisions are notified. Internal prices and comments are no longer visible.
Everyone	Deactivated users and role changes take effect on the next request. Overdue tasks escalate to the manager role.

7. Open items and decisions

Item	Status / decision needed
DMN-01 band edges (exactly ₹2 L, ₹10 L)	Left as is: the upper bound is exclusive, so exactly ₹10 L needs the larger chain (more control). The spec's table can be read either way; decide and we align the rule and the simulator
Escalation: add the manager, or reassign	Implemented as "add the manager role, original approvers can still act". Change to strict reassignment if wanted
Multi-item sourcing events	Restricted to one item; per-line evaluation is a larger change if needed
Quote attachments	Quote references are stored; real attachments need a document store (schema decision)
MRP 10-minute target	681 s measured; see §5
Tally lookup	Verify against a real Tally gateway
`rules.resolve` and connector checks	Central check that an ERP connector maps a message type is done at the call sites; can move into `integration.enqueue`

8. Test evidence

Run	Result
Full backend suite, one database, all dataset packs	**389 passed**: 387 in the full run, plus 2 tests whose expectations changed with the band and back-off defaults, then re-run and passed
New review tests	F2/F9 22 · F3/F4 13 · F5/F6 31 · F7/F8 22 · platform 17 · MRP 9
Migration 0007	upgrade → downgrade → upgrade round trip; `alembic check` clean
Frontend	`tsc --noEmit` clean. ESLint has 3 errors, all from before this work, in `materials/[ref]/page.tsx` (shared component), which the CI lint scope excludes
Local Neon rehearsal	Fresh build with all 8 companies and 10 dataset packs. Atomic swap committed; verification shows row-level security forced on 112 of 115 tables and every audit chain valid